Case study: the Moldova e-Government breach

October 2026 · What happened, what the risks are, and how to prevent it

Based on official statements and press reports up to 28 October 2026. Findings are preliminary.

Today's agenda

01	**What happened**	Numbers, timeline, data exposed
02	**How it happened**	What is publicly known about the attack
03	**The risks**	For citizens and for the state
04	**How to prevent it**	Citizens, developers, organizations
05	**Discussion**	Class exercise and key takeaways

PART 01 OF 05

01 What happened

19–23 October 2026: data about one in three Moldovans



The breach in numbers

~1 million

personal ID numbers (IDNP) queried by the attackers

~750,000

people whose data sets were extracted

1 in 3

Moldovans affected (population ~2.4 million)

82 + 30

public services and information systems taken offline

5 days passed between the start of the attack (19 October) and the moment it was stopped (23 October, 11:30). *Source: AGE and STISC, preliminary findings.*

Timeline



19–23 Oct	23 Oct, 11:30	24 Oct	25 Oct, 02:00	27 Oct, 07:00	28 Oct
~1 million IDNPs queried, data extracted	Extraction stopped. 82 services and 30+ systems disconnected	Attack announced publicly	New forced-access attempt blocked	New extraction attempts fail. AGE publishes details	AGE director steps down. Two MPass login methods paused

Also on 28 October: the Prime Minister said Moldova is the target of “coordinated and large-scale cyberattacks” and that possible involvement of foreign state actors is being examined. No attribution has been made public.

What data was exposed



Identity

Name, date and place of birth, IDNP, photo



Family

Data about first-degree relatives



Health and social

Insurance status, family doctor, benefits, pension, disability



Documents and assets

Driving licence, vehicles, companies owned or managed



Financial

IBAN, tax debts, MPay payment history



Not affected

Bank card data. No changes found in state registers

Not every affected person had every category exposed (AGE, STISC).

PART 02 OF 05

02

How it happened

What is publicly known so far



The attack, as described by the authorities



Entry point: vulnerabilities in services accessible without authentication. *(AGE)*

Chaining: the data obtained was then used for further extractions from connected systems. *(AGE)*

Scale: about 1 million IDNPs queried; about 11 million requests reported. *(AGE, The Record)*

Audit trail: one e-service recorded the wrong legal basis, so some people saw misleading entries in their EVO access history. *(AGE)*

Four weaknesses the facts point to



No login in front of personal data

Services returned data about any person without checking who was asking.

OWASP A01 Broken Access Control



No effective limits

Around a million lookups over five days were possible before the attack was stopped.

OWASP A09 Logging & Alerting



Too much data per query

One query unlocked data from many connected registers: identity, family, money.

OWASP A06 Insecure Design



Unreliable audit trail

A wrong legal basis was logged, so the access history misled citizens.

OWASP A09 Logging & Alerting

This is our analysis of the public information, not an official finding.

PART 03 OF 05

03 The risks

Stolen data does not expire



What criminals can do with this data

Fake bank calls

They know your IBAN and recent payments, so the call sounds real.

“Your son is in trouble”

They know your relatives' names and can invent a believable emergency.

Fake officials

Tax debts, cars, pension: perfect details for a fake inspector or ministry.

Targeting the vulnerable

Pension and disability data shows who is easiest to pressure.

Identity fraud

Name, IDNP, birth date and photo help impersonate you.

Risk for years

You can change a password, but not your birth date, IDNP or family.

Case study: Moldova e-Government breach, October 2026

Anatomy of a scam built on leaked data

SMS · necunoscut

Stimată doamnă **Maria Popescu**, am observat o plată suspectă din contul **MD24…7731** după achitarea **impozitului auto din 12.10**. Pentru a bloca operațiunea **în 15 minute**, **comunicați codul primit prin SMS** operatorului care vă va suna.

Real data from the leak

Name, IBAN, a real MPay payment: it feels legitimate.

Urgency

“15 minutes” leaves no time to think or check.

Asks for a code

No bank or institution ever asks for your SMS code.

The right reaction

Hang up. Call the bank on the number printed on your card.

Case study: Moldova e-Government breach, October 2026

Not an isolated incident

2nd

major breach of Moldovan state systems in 2026. The healthcare database was breached in April

Risky Bulletin

2,600

of 8,200 cyber incidents analyzed in the EU hit public administration, the most targeted sector

ENISA, September 2026

Hybrid

authorities see the attack as possibly part of a wider hybrid campaign against Moldova

Government of Moldova

Why governments? They hold complete, verified data about everyone, connect many old and new systems, and are a political target.

PART 04 OF 05

04

How to prevent it

Citizens, developers and organizations



What you can do as a citizen, today

Check your data access history

EVO app → Contul tău → Istoricul accesării datelor

Never share passwords or SMS codes

No bank, police officer or ministry will ever ask for them

Hang up and call back

Use the official number from the card or website, not the one from the message

Agree on a family code word

Ask for it when someone “from the family” urgently needs money

Turn on bank notifications

Report any transaction you do not recognize immediately

Do not open unsolicited links

And never approve payments requested by strangers

What developers and organizations must do



Prevent

- Authenticate every endpoint that returns personal data
- Authorize per record and per purpose: who may see what, and why
- Return the minimum data needed; mask IDNP and IBAN
- Least privilege between connected systems
- Keep an inventory: no forgotten or test services online



Detect and respond

- Rate limits and quotas per client and per API key
- Alerts on unusual volume: a million lookups is never normal
- Reliable audit logs: who accessed what, when and why
- A tested incident response plan
- Regular audits and penetration tests

The response: what worked, what is unknown

What worked

- The attack was detected and stopped
- Fast containment: 82 services and 30+ systems offline
- Public disclosure the next day, with clear advice
- Joint investigation: AGE, STISC, ASC, SIS, police
- Services return only after new security checks

Open questions

- Why could these services be used without login?
- Why did five days of mass queries not trigger alarms sooner?
- Do other systems share the same design?
- Exactly how many people were affected?
- Who is behind the attack?

You will practice exactly this in our labs

Lab 1	Threat model and attack surface: which endpoints are public and what they expose
Lab 2	Input validation and safe database queries
Lab 3	Authentication, per-record authorization (IDOR) and rate limiting on login
Lab 4	Logs and Fail2ban: detecting and blocking abusive clients automatically
Lab 5	Nginx rate limiting, HTTPS, security headers, secrets kept out of code

The Notes app has the same kind of flaw: in Lab 3 you will find an endpoint that returns other people's notes to anyone who asks.

PART 05 OF 05

05 Discussion

Think like the security team



Class exercise: you are the security team (20 min)

1 **Map the attack surface**

Which public services return personal data? Which need login and which do not?

2 **Choose three controls**

If you could deploy only three defenses tomorrow, which ones and why?

3 **Write one alert rule**

What exact condition should have raised an alarm on 19 October?

4 **Notify the citizens**

Write a short, honest SMS to affected people: what happened and what to do.

Groups of 3–4 students. Each group presents one answer in 2 minutes.

Key takeaways



No authentication = public data

If an endpoint answers anyone, assume attackers will ask it a million times.



Limits and alerts are not optional

Rate limiting and monitoring turn days of silent theft into minutes.



Connected systems multiply the damage

Give each system only the data it really needs.



People are the final target

Leaked data powers scams for years. Teach your family to verify, not trust.

Sources

AGE, official statement, 27 Oct 2026 egov.md/ro/node/41145

Moldpres, STISC findings, 28 Oct 2026 moldpres.md

The Record, 28 Oct 2026 therecord.media/moldova-investigates-possible-foreign-involvement-cyberattacks

Risky Bulletin, 28 Oct 2026 news.risky.biz

Diez.md, how to check your data, 27 Oct 2026 diez.md

NewsMaker, MPass changes, 28 Oct 2026 newsmaker.md

Pro TV Chișinău, AGE leadership change, 28 Oct 2026 protv.md

ENISA Threat Landscape, 22 Sep 2026 (via Moldpres) enisa.europa.eu

Information as of 28 October 2026. The investigation is ongoing and figures are preliminary.



Check your EVO access history today

Then help one older relative do the same · Questions?